

You report a vulnerability to a Company through their official bug bounty program but the Company threatens legal action against you instead of paying the promised reward, claiming you "exceeded Authorized Scope". Discuss the disclosure and legal risks researchers face, and how to mitigate them beforehand.

Introduction :-

Bug bounty programs encourage security researchers to identify and responsibly report security vulnerabilities. These programs help organizations improve their security vulnerabilities. These programs reward researchers for their efforts. However, disputes may arise if a company believes the researcher has gone beyond the authorized scope of testing, leading to legal risks instead of rewards.

Disclosure and Legal Risks Faced by Researchers

1. Scope Violation Claims

A company may claim that the researcher tested systems or performed actions that were outside the approved scope of the bug bounty program.

2. Legal Action

Researchers may face legal notices or lawsuits under Cybercrime or computer misuse laws if the organizations believe unauthorized access control occurred.

3. Denial of Bug Bounty Reward

Even if the reported vulnerability is genuine the company may refuse to provide the promised reward due to alleged policy violations.

4. Reputational Damage

Legal disputes may affect the researcher's professional reputation and future participation in bug bounty programs.

5. Financial And Time Costs.

Responding to legal claims may require legal assistance, resulting in financial expenses and loss of time.

How Researchers Can Mitigate These Risks

1. Read the Bug Bounty Policy Carefully

Understand the program rules, scopes, testing limitation and reward conditions before starting any testing

2. Stay within the Authorized Scope

Test only the domains, Application, and system that are explicitly included in the program.

3. Maintain Proper Documentation

Keep screenshots, logs, timestamps, and records of all testing activities to prove that testing was conducted responsibly.

4. Avoid Accessing Sensitive Data

Do not download, modify, or expose confidential user or company information unless explicitly permitted.

5. Use Responsible Disclosure

Report vulnerabilities through the official reporting channel and avoid public disclosure until the company has had sufficient time to fix the issue.

6. Seek Clarification When Needed

If any part of the scope is unclear, obtain written confirmation from the organization before proceeding with testing.

7. Review Safe Harbor Policies

Participate in programs that provide legal protection (Safe harbor) for researchers acting in good faith

Importance of Responsible Vulnerability Disclosure

⇒ Helps organizations identify and fix security vulnerabilities before they are exploited by attackers.

⇒ Reduces the risk of data breaches, financial losses, and damage to the organization's reputation

⇒ Promotes ethical hacking by encouraging researchers to follow legal and responsible practices.

⇒ Builds Trust and Cooperation between security researchers and organizations.

⇒ Ensures vulnerabilities are reported through official channels instead of being publicly disclosed immediately.

⇒ Protects users by allowing companies sufficient time to release security patches.

⇒ Supports a safer cybersecurity ecosystem by promoting responsible disclosure & collaborations

⇒ Encourages organizations to improve their bug bounty programs and security policies.